DEV-07 · Personally-Owned Device Access Standard

What your own phone or laptop may reach, what the organization can and cannot see on it, and what happens when you leave.

Field	Value
Document ID	DEV-07
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 4 — IT Management owns the position; Tier 2 supports it.
Review cycle	Annually.
Related existing policy	Your organization's acceptable use policy, which applies to a personal device being used for organization work exactly as it does to an organization one. Check §2 against it before publishing.

1. Purpose

Most people in most organizations read work email on a personal phone, and most of them should be able to. This document says what that involves on both sides — what the device may reach, what the organization asks of it, and what the organization can and cannot see.

It is written to be read by the person whose device it is, because the main risk with a personal-device policy is not technical. It is that people either assume the organization is watching everything, or assume it is watching nothing, and both assumptions cause problems.

2. The bargain

> **The organization protects its data. It does not manage your device.**
>
> Using a personal device for organization work means the organization applies protections to organization data on it — requiring a passcode to open an organization app, preventing organization files being copied into a personal one, and being able to remove organization data if the device is lost or you leave.
>
> It does not mean the organization manages the device, sees your photos, reads your personal messages, tracks where you are, or can wipe the whole thing. Section 5 says exactly what is and is not visible.
>
> If that bargain is not acceptable to you, that is a legitimate position: use an organization device instead, or do not use a personal device for organization work. Neither carries any consequence.

3. Two ways a personal device can be used

	App protection (the normal way)	Full enrollment (rare)
What it is	Protection applied to organization apps only. The rest of the device is untouched and unmanaged.	The device is enrolled in management like an organization device.
Who it is for	Everybody. This is the default and covers reading mail, joining Teams, opening a document.	Only where a role genuinely requires it, and only by agreement. Rare, and it should stay rare.
What the organization applies	Passcode or biometric to open organization apps. No copy-paste from organization apps into personal ones. No saving organization files to personal storage. Encryption of organization data at rest.	The full DEV-02 baseline, as for an organization device.
What the organization can remove	Organization data from organization apps. Nothing else.	Potentially the whole device, which is why this is not the default.
Recommended	Yes.	Only where there is no alternative — and consider issuing an organization device instead.

The strong preference for app protection over full enrollment is deliberate. It achieves the organization's objective — protecting organization data — without acquiring the ability to do things to somebody's personal property that the organization does not want and should not hold.

4. What a personal device may reach

Classification	On a personal device
PUBLIC	Freely.
INTERNAL	Yes, through organization apps with app protection applied. Email, Teams, files — the ordinary case.
CONFIDENTIAL	Through managed organization apps only, with no local copies. Do not download client records, job applicant files or personnel records onto a personal device.
RESTRICTED	No. Not on a personal device in any circumstance — this includes social security numbers, payment card data, health records and credentials (M365-15 §5).

The practical version, for a person: reading it on your phone is fine; downloading it to your phone is where the line falls, and for the most sensitive material even reading it should be done somewhere else.

5. What the organization can and cannot see

Stated plainly, because guessing is worse than knowing. Under app protection, which is what almost everybody will have:

The organization can see	The organization cannot see
That a device is being used with an organization account, and its make, model and operating system version.	Your photos, personal files, or anything outside organization apps.
Whether organization apps are protected as required.	Your personal email, messages or calls.
Which organization apps are in use.	Your other apps, or that you have them.
Sign-in activity for your organization account, as for any device.	Your browsing history.
That organization data has been removed, when it removes it.	Your location.

- The organization does not read personal content, and has no mechanism to do so under app protection.
- Log access for a security investigation is a Tier 4 decision with a recorded reason, and where it concerns an employee, HR is involved from the start (ACC-15 §6).
- Under full enrollment the organization can see and do considerably more, which is precisely why §3 makes it rare and by agreement.

6. When you leave

- Organization data is removed from organization apps on your device. Your device, your photos, your personal accounts and your apps are untouched.
- This happens as part of the leaver procedure (ACC-01 §7.2) and is not a discretionary act.
- Under full enrollment, removal is scoped to organization data wherever the platform allows it. A full device wipe is never performed on personal property without the owner's explicit, contemporaneous agreement.
- If anything of yours is genuinely mixed into organization storage, tell IT before your last day. It is much easier to separate then.

7. The phone carrying your Authenticator

> **Your phone is part of the organization's identity perimeter, whether or not it holds any organization data.**
>
> The device with your multifactor method on it can approve a sign-in. That makes it security-relevant even if you never read email on it.
>
> Three consequences follow, and they are the practical heart of this document:
>
> 1. Keep a passcode or biometric on it. This is the whole protection.
> 2. Register a second MFA method on something else. One method on one phone means one lost phone is a service desk visit with photo ID (ACC-03 §5.3).
> 3. Before you replace, sell or trade in that phone, register the method on the new one first. Two minutes then; a verified in-person recovery otherwise.

8. What is never permitted

- RESTRICTED data on a personal device, in any form (§4).
- Letting anybody else use a device while signed in to your organization account, or sharing your credentials with anybody — including family (ACC-15 §3).
- Copying organization data out of organization apps into personal storage, personal cloud accounts, or personal email.
- Using a personal device to hold the only copy of anything the organization needs (M365-12).
- Connecting a personal device to the administrative network, or using one for privileged administrative work (ACC-07 §3).
- Jailbroken or rooted devices, which cannot be protected in the way §3 assumes.

9. Service levels

Activity	Commitment (per GOV-06)
Help setting up organization apps on a personal device	P3 — Tier 1, usually in the conversation.
Personal device lost, holding organization data	P2 — organization data removed within 4 coverage hours (DEV-16).
Full enrollment request	P3 to Tier 4 — expect to be offered an organization device instead.
Organization data removal on separation	With the ACC-01 leaver procedure.
“What can you see on my phone?”	Answered at Tier 1 from §5. It is a fair question and deserves a straight answer.

10. Records

Record	Held in	Retention
Devices with organization app protection applied	Management platform	While in use
Full enrollment agreements, with the owner’s consent recorded	Ticket + Tier 4 record	Life of the arrangement + 3 years
Organization data removals	Ticket	3 years
Log access decisions	Tier 4 record	7 years

11. Related documents

ID	Title	Relationship
AUP	Your organization's acceptable use policy	Applies to personal devices used for organization work. Check §2 and §8 against it.

ID	Title	Relationship
M365-15	Data Classification & Handling	Supplies §4.
DEV-01	Device Enrollment & Lifecycle	Personal devices are explicitly out of its scope.
DEV-02	Device Compliance & Configuration Baseline	Applies only under full enrollment.
DEV-08	Mobile Device Access to organization Data	The mobile-specific detail.
DEV-16	Lost, Stolen or Compromised Device Response	§9, and the lost personal device case.
DEV-10	Remote Access & VPN Standard	Personal devices connecting remotely.
ACC-03	MFA Enrollment	§7 — the phone carrying the method.
ACC-15	Acceptable Use & Credential-Sharing Standard	§8, and the monitoring position in §5.
ACC-01	Account Lifecycle	§6 — removal at separation.
M365-12	OneDrive Appropriate Use	Never the only copy.

Appendix A — End-user text

Source text for the knowledge base. Format per GOV-05.

Using your own phone for work email	Perfectly fine, and most people do. We apply protection to the organization apps — a passcode to open them, and a rule that organization files cannot be copied into personal apps.
What we can see	That the device exists, its model and OS version, and that organization apps are protected. That is all. Not your photos, messages, browsing, other apps or location.
What we can remove	Organization data from organization apps. We cannot wipe your device, and we would not.
What not to put on it	Do not download client records, job applicant files or personnel records to a personal device. Read them in the app instead. Never anything with social security numbers, card details or health information.
Your Authenticator phone	Keep a passcode on it, register a second method on something else, and set up the new phone BEFORE you get rid of the old one. That last one saves you a trip to the service desk with photo ID.
When you leave	We remove organization data from organization apps. Nothing else on your device is touched.
If you would rather not	Then do not — use an organization device, or just do organization work at work. There is no expectation and no consequence.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.